Federated GA4GH Passport authorization in the Beacon Network

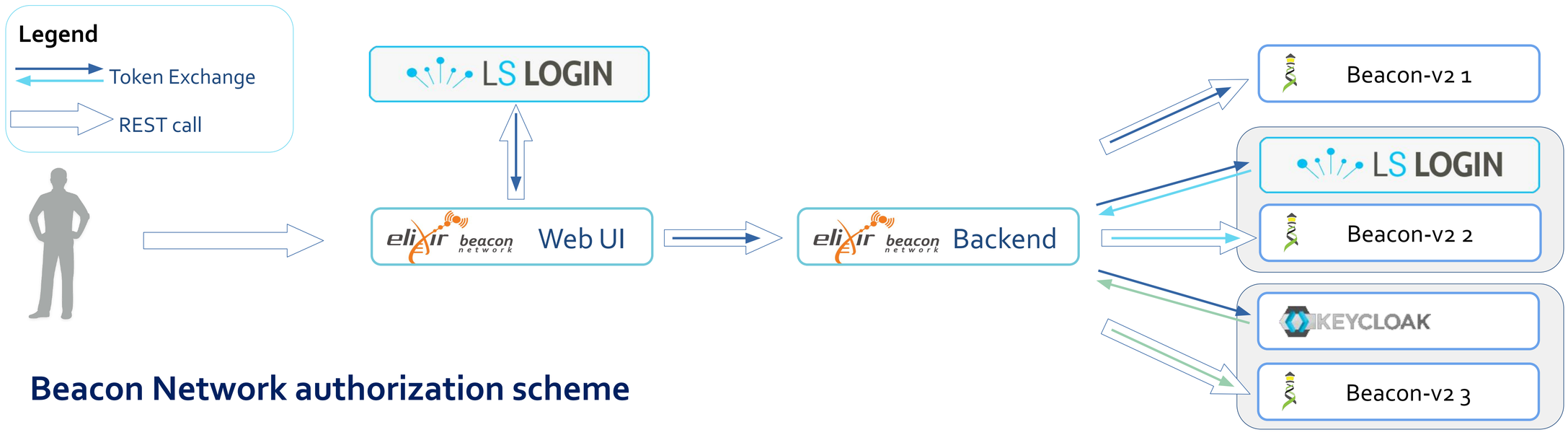
Dmitry Repchevsky[1,2], Sergi Aguiló-Castillo[1,2], Salvador Capella-Gutierrez[1,2], Josep Lluís Gelpí [1,2,3]

[1] Barcelona Supercomputing Center (BSC), [2] Spanish National Bioinformatics Institute (INB/ELIXIR-ES), [3] Universitat de Barcelona

ELIXIR All Hands , 10-12 June 2024, Uppsala, Sweden

Although the Beacon v2 specification does not determine a concrete authentication scheme, **OpenID Connect (OIDC) is the most popular authentication protocol**, supported by many Beacon v2 implementations. When queried, the **Beacon Network** v2 or "Beacon of Beacons" transparently passes HTTP Authorization to the registered beacons. This behaviour is suitable when all beacons trust the same authentication provider but not sufficient when a particular node wants to keep the control over its resources.

To provide Federated Authentication/Authorization, Beacon Network may initiate a token exchange mechanism (RFC 8693), passing the authorization responsibility on to the corresponding authentication server. Any protected Beacon must define this server via the OAuth 2.0 Protected Resource Metadata standard endpoint or the OpenAPI securitySchemes. When the beacon sets no specific authentication server, or the OIDC token issuer matches the server, the Beacon Network server transparently passes the credential header to the queried beacons.



Beacon Network authorization scheme

To demonstrate the **feasibility of this orchestration**, we provide a configured BSC demo identity provider linked to the LS-AAI and configured to support a token exchange mechanism. BSC's Java Beacon v2 implementation has been updated to provide the OAuth 2.0 Protected Resource Metadata and is configured to authenticate via the BSC provider.

Notably, the ELIXIR Beacon Network implementation has been updated to support transparent token exchange orchestration.

https://beacons.bsc.es/beacon/v2.0.0/.well-known/oauth-protected-resource

```
{
  "resource": "https://beacons.bsc.es/beacon/v2.0.0/",
  "authorization_servers": [
    "https://inb.bsc.es/auth/realms/beacon/"
  ],
  "client_id": "beacon"
}
```

OAuth 2.0 Protected Resource Metadata

```
Host: inb.bsc.es
POST /auth/realms/beacon/protocol/openid-connect/token HTTP/1.1
client_id=beacon & subject_token=$LS_TOKEN
grant_type=urn:ietf:params:oauth:grant-type:token-exchange
subject_token_type=urn:ietf:params:oauth:token-type:jwt
requested_token_type=urn:ietf:params:oauth:token-type:access_token
```

Exchange Life Science token with Beacon Access Token

Beacon v2 providers may define their own Authorization server for protecting their genomic and phenoclinic data. In this case, it must inform the ELIXIR Beacon Network backend with the authorization server and Public Client ID configured for the Token Exchange mechanism via OAuth 2.0 Protected Resource Metadata endpoint.

The ELIXIR Beacon Network will use OpenID Connect Discovery to resolve the proper Authorization Server. If the token diverges from the one expected by the Beacon Instance, it will perform a **Token Exchange** with the server required by the Beacon.

This mechanism offers **enough flexibility** to allow Beacon Providers to protect their data/metadata and have full access control while facilitating providers that rely on Life Sciences tokens to keep using it without needing their own authorization servers.

Dmitry Repchevsky
Research Engineer
dmitry.repchevski@bsc.es

GDI project receives funding from the European Union's Digital Europe Programme under grant agreement number 101081813.

Funded by the European Union

/company/elixir-europe